

Data Retention Policy

wiki/legal/data-retention · Updated 2026-04-10 · Owner: Legal

Purpose

This policy defines how long Northwind retains different categories of data and how data is disposed of at the end of its life. It is maintained by the Legal team and applies to all systems that store company or customer data.

Retention is a balance between regulatory obligations, business needs, and the principle of not keeping data longer than necessary.

Principles

- Keep data only as long as there is a legal or business reason.
- Classify data so that retention and controls match its sensitivity.
- Automate disposal so expired data does not accumulate.
- Honour deletion requests promptly and verifiably.

Retention periods

- Customer transaction records are retained for 7 years to meet regulatory requirements.
- Application logs are retained for 90 days.
- Backups are retained according to their own schedule and purged when expired.

- Analytics data is retained in aggregated form only after its raw window closes.

Why these periods

Transaction records are kept for seven years because financial and tax regulations require it. Operational logs are kept only as long as they are useful for debugging and security investigations, which is why their window is short. Keeping logs forever would raise cost and privacy risk with little benefit.

Personal data

Personal data deletion requests are processed within 30 days. When a verified request is received, personal data is removed or anonymised across primary systems and scheduled for removal from backups as they roll off.

- Requests are verified before any data is deleted.
- Deletion covers primary stores and propagates to downstream systems.
- Some records may be retained where law requires, with a documented basis.

Handling a deletion request

When a deletion request arrives, verify the requester's identity, locate the personal data across systems, delete or anonymise it in primary stores, and record that the request was completed. Data in backups is removed as those backups expire on their normal schedule.

Disposal

Backups older than their retention window are purged automatically each month. Automated jobs enforce retention so that expired data does not linger. Manual deletion of production data requires approval and is logged.

Secure disposal

Disposal must be irreversible. Deleting a pointer while the underlying data remains recoverable is not disposal. For physical media, follow the secure destruction process.

Access and auditing

Access to retained data follows least privilege and is reviewed periodically. Access to sensitive historical records is logged, and the logs themselves are retained for audit.

Worked example

A customer requests deletion of their personal data. The team verifies the request, removes the personal fields from the primary database and the downstream analytics store within the 30-day window, and records completion. The customer's transaction records, which must be kept for seven years for tax reasons, are retained with a documented legal basis but stripped of unnecessary personal detail.

Frequently asked questions

How long are transaction records kept? Seven years, to meet regulatory requirements.

How long are application logs kept? 90 days.

How fast are deletion requests handled? Within 30 days of a verified request.

Common mistakes

- Keeping logs indefinitely "just in case," raising cost and privacy risk.
- Deleting a reference while the underlying data remains recoverable.
- Processing a deletion request without verifying the requester.
- Forgetting that some records must be retained even after a deletion request.

Responsibilities

Service teams implement retention controls in their systems. Legal defines the required periods and reviews them when regulations change. Security reviews the controls as part of regular audits.

Exceptions and legal holds

When data is subject to a legal hold, normal retention and deletion are suspended for the affected records until the hold is lifted. Legal manages holds and notifies the relevant teams.

Related documents

See the Updated Security Standards for data classification and protection, and the Database Backup Procedure for how backups are retained and purged.

Compliance and audit

Retention is not only good hygiene; for several data categories it is a legal obligation. The periods in this policy are set so that Northwind can demonstrate compliance to auditors and regulators on request. Keep the mapping between data category and retention period documented and current.

- Maintain a register of data categories, their retention periods, and the legal basis.
- Record when automated purges run and whether they succeeded.
- Keep evidence that deletion requests were completed within the required window.
- Review the register whenever a regulation or business process changes.

Auditors typically ask two questions: can you show what you keep and why, and can you show that you delete what you should. A current register and reliable purge logs answer both.

Data minimisation

The cheapest data to protect is the data you never collected. Before adding a new field or log, ask whether it is actually needed and for how long.

- Collect only the data a feature genuinely requires.
- Prefer aggregated or anonymised data where the raw detail is not needed.
- Set a retention period for every new data store at the time it is created.
- Delete prototype and test data sets that are no longer in use.

Minimisation reduces both cost and risk: there is less to store, less to secure, and less to expose if something goes wrong.